

Phase 4 - Security & Testing Report

Community Garden Management System | Testing date: 29 September 2026

Prepared from actual PHPUnit feature tests, Chromium browser checks, screenshots, and targeted source review. All 86 backend cases and 18 browser cases passed after one validation correction. Human usability sessions and leader-approved contribution ratings are pending; this package is not ready for final submission until those records are completed.

Environment, method, and evidence

Laravel 13 / PHP 8.4; React 19 / TypeScript / Inertia. Backend tests use a fresh in-memory SQLite database. Browser checks use an isolated seeded SQLite database at `/private/tmp/websys2-phase4-20260929.sqlite` and a loopback-only server at `http://127.0.0.1:8765`, with the production frontend bundle and database sessions. The normal application database and `.env` were not changed.

Alternative to Nessus: PHPUnit HTTP/security tests, Playwright-driven browser checks, and source inspection. Nessus was not run. These checks cover application behavior for the listed inputs; hosted PostgreSQL, deployment configuration, dependency vulnerabilities, concurrent load, and a comprehensive penetration test were not assessed.

Canonical backend evidence: `EVIDENCE/phpunit-results.xml` and `phpunit-results.txt`. Browser evidence: `EVIDENCE/browser-results.json`, `browser-auth.txt`, `browser-features.txt`, and `SCREENSHOTS/*.png`. Each backend method name in the inventory maps directly to the JUnit XML. Screenshots are accompanied by exact inputs and observations rather than treated as proof by themselves.

For screenshots B01, B02 and B17, the harness disables native HTML form constraints in its own browser DOM to verify server validation and display the returned messages. The application source retains its native constraints. Test credentials are development-only fixtures from `README.md`; no real credentials or session-cookie values are included.

A. Input Validation Test

Test case	Input / procedure	Expected result	Actual result	Status
VAL01 Empty required fields	Login email/password blank	Reject both fields	HTTP 422; email and password errors; guest	PASS
VAL02 Invalid email	Email abc	Reject malformed email	HTTP 422; email error; guest	PASS
VAL03 Registration name length	Name A; other fields valid	Reject name shorter than 2 characters	HTTP 422; name error; no user created	PASS
VAL04 Duplicate email	Existing phase4@example.test	Reject duplicate account	HTTP 422; email error; user count unchanged	PASS
VAL05 Password length	Password/confirmation short	Require at least 8 characters	HTTP 422; password error; no user created	PASS
VAL06 Password confirmation	Garden123! / Mismatch123!	Reject mismatch	HTTP 422; password error; no user created	PASS
VAL07 Plot numeric and enum validation	Size -1; status invalid	Reject negative size and unknown status	HTTP 422; both errors; no plot created	PASS
VAL08 Request note bounds	Blank, short, and 501 x characters	Require 10-500 characters	HTTP 422 for each payload; no request created	PASS
VAL09 Event date ordering	Start 2026-09-29 10:00; end 09:00	End must follow start	HTTP 422; ends_at error; no event created	PASS

B. SQL Injection Test

SQL04 and SQL05 attach a QueryExecuted listener and inspect actual query templates and bindings. The malicious string must appear in the binding values and must be absent from the SQL template. Tests also assert result counts, unchanged records, and continued existence of users. A rejected login alone would not establish parameterization. Search interpolation forms a LIKE binding value; it does not interpolate into SQL syntax. ReportController uses only a constant aggregate selectRaw expression.

Test case	Input / procedure	Expected result	Actual result	Status
SQL01 Login email injection	' OR '1'='1' --	No login bypass	HTTP 422; invalid email; guest; users unchanged	PASS
SQL02 Password tautology	' OR 1=1 --	No login bypass	HTTP 422; credential error; guest	PASS
SQL03 Password UNION payload	' UNION SELECT 1,2,3 --	No login bypass	HTTP 422; credential error; guest	PASS
SQL04 Search parameter binding	Search: ' OR 1=1 --	Treat as literal search data	HTTP 200; 0 matches; payload in bindings, absent from SQL template; plot remains	PASS
SQL05 Stacked statement in plot code	T'); DROP TABLE users;--	Store text without executing SQL	Exact text persisted; users table intact; payload in bindings, absent from SQL template	PASS
SQL06 Numeric ID injection	garden_plot_id: 1 OR 1=1	Reject non-integer ID	HTTP 422; ID error; no request created	PASS
SQL07 Legitimate apostrophe	Name: Maria O'Brien	Allow ordinary punctuation safely	Account created as member; exact name preserved	PASS

C. Authentication Test

Existing AuthenticationTest additionally verifies valid login and logout for all three roles, incorrect credentials, registration with hashed passwords, and guest redirects. Session lifetime is configured to 120 minutes with database storage outside tests. Expiry after elapsed time and other-device session revocation were not tested. The implemented password requirement is at least 8 characters plus confirmation, with the current password required for a change; mixed character types are not required.

Test case	Input / procedure	Expected result	Actual result	Status
AUTH01 Session handling and logout	Valid login, logout, then protected URL	Rotate session on login; invalidate on logout	Session IDs differ; CSRF token rotates on logout; guest; protected URL redirects	PASS
AUTH02 Login throttling	5 incorrect passwords then correct password	Reject sixth attempt during lockout	Throttle message; guest remains unauthenticated	PASS
AUTH03 Suspended account login	Correct password for inactive user	Deny login	HTTP 422; credential error; guest	PASS
AUTH04 Suspended active session	Suspend logged-in user, revisit dashboard	Force logout and invalidate session	Login redirect; suspended-account message; guest; new session and CSRF token available	PASS
AUTH05 Password-change verification	Incorrect current password	Reject change	HTTP 422; current-password error; original password hash still valid	PASS
AUTH06 Anonymous API access	GET plots and POST request without login	Require authentication	Both return HTTP 401	PASS

D. Authorization Test

Authorization is enforced by Laravel auth/active/role middleware and controller checks, including direct HTTP requests. Staff handles operations; admin handles members and reports. Admin does not automatically gain staff pages. Existing ownership tests cover another member's requests, plantings and notifications, and member-specific data filtering.

Test case	Input / procedure	Expected result	Actual result	Status
ROLE01 Registration role escalation	role=admin; is_active=false	Registration creates active member only	Stored role member; account active	PASS
ROLE02 Self-promotion attempt	Member PUT own /members/{id}; role=staff	Deny member-access management	HTTP 403; role remains member	PASS
ROLE03 Staff access-change attempt	Staff PUT member role/status	Only admin may manage access	HTTP 403; target member unchanged	PASS
ROLE04 Self-approval attempt	Member POST own request /approve	Only staff may approve	HTTP 403; request pending; no assignment created	PASS

Role	Page / feature	Expected access	Actual access	Status
Admin	GET /members; GET /reports; report export	Allowed	Allowed, HTTP 200	PASS
Member	GET /members; GET /reports	Denied	Denied, HTTP 403	PASS
Staff	GET /members; GET /reports	Denied	Denied, HTTP 403	PASS
Staff	Plot/crop/event management and request approval	Allowed	Allowed; changes persisted	PASS
Member	POST plot/crop management; own request approval	Denied	Denied, HTTP 403	PASS
Admin	Garden plots / requests / assignments / calendar	Denied	Denied, HTTP 403	PASS

E. XSS Test

Storing a payload string as data is permitted. The protection is escaping at output and React text rendering, rather than stripping every angle bracket. The backend tests establish safe initial HTML and data transport. B09 adds a cross-user browser check for stored script, image handler, and SVG handler payloads: no executable nodes are created and `window.__phase4Xss` remains 0. B10 verifies reflected search text. The stored-profile payload has backend evidence only; browser execution checks focus on announcements and search.

Test case	Input / procedure	Expected result	Actual result	Status
XSS01 Stored profile script	<code><script>window.__phase4Xss=1</script></code>	Return input as escaped data	Exact name stored; Inertia property equals payload; raw tag absent from initial HTML	PASS
XSS02 Stored announcement handler	<code></code>	Return input as escaped data	Exact body stored; Inertia property equals payload; raw tag absent from initial HTML	PASS
XSS03 Reflected search handler	<code><svg onload="window.__phase4Xss=3"></code>	Reflect search as escaped data	Literal filter value; 0 matches; raw tag absent from initial HTML	PASS

F. Functional Testing

Feature	Test procedure	Expected result	Actual result	Status
Registration / login / logout	Submit valid member registration; log in and out with each role Evidence: AuthenticationTest	Hashed member account and role redirects; logout clears access	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Plot inventory and archiving	Staff archives an unused plot; API reads current plots Evidence: OperationalWorkflowTest	Plot archived without losing history; structured JSON returned	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Plot requests and approval	Member submits a valid request; staff approves it Evidence: OperationalWorkflowTest	Request approved, assignment created, plot occupied, member notified	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Request cancellation / resubmission	Cancel pending own request and submit again Evidence: MemberBackendTest	Updated history and new pending request	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Assignment constraints / closing	Attempt duplicate active assignment; close current assignment Evidence: MemberBackendTest	Duplicates rejected; closed assignment releases only its own plot	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Crop add / edit	Staff adds and edits crop name/type Evidence: CropPlantingTest	Crop values saved and returned to the page	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Member plantings	Plant a crop on own active plot with valid dates Evidence: CropPlantingTest	Planting saved and displayed on own assignment	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Search / sorting / pagination	Search titles/body; change sort; open next page Evidence: CommunityUpdatesTest	Matching published records; stable sort; filters preserved	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Announcement lifecycle	Staff/admin creates, edits, publishes, then archives an update Evidence: CommunityUpdatesTest	Member sees full published content; archived/draft content hidden	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Garden calendar / notifications	View published schedule; staff publishes draft event Evidence: WorkspaceNavigationTest; OperationalWorkflowTest	Complete published schedule supplied; active users notified	Verified by passing HTTP, data and database assertions in the named test class.	PASS

Feature	Test procedure	Expected result	Actual result	Status
Profile / password settings	Change profile and password using correct current password Evidence: OperationalWorkflowTest	Profile updated; new password hash validates	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Member administration	Admin suspends member; attempt login Evidence: OperationalWorkflowTest	Access updated; suspended member cannot sign in	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Reports / CSV	Admin requests date-filtered report export Evidence: OperationalWorkflowTest	HTTP 200 with text/csv content type	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Notification ownership	Mark own notification read; try another member's notification Evidence: MemberBackendTest	Own read action allowed; another member's action denied	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Navigation / help / role pages	Open allowed workspaces as each role and as guest Evidence: WorkspaceNavigationTest	Allowed pages load with personal labels; restricted/guest requests denied	Verified by passing HTTP, data and database assertions in the named test class.	PASS
Database relationships / sample data	Migrate fresh database; check relations; seed twice Evidence: DatabaseFoundationTest	Relationships available and repeatable demo data	Verified by passing HTTP, data and database assertions in the named test class.	PASS

The complete 86-method inventory appears below. The functional table summarizes related assertions and is not added again to test-case totals. Browser B11 verifies adding and searching a real record through the frontend, and B14 verifies an actual CSV response.

G. Usability Testing

Status: PENDING HUMAN TESTERS. Automated mobile checks B07 and B18 confirm one 390 x 844 layout and the navigation menu, but do not substitute for human feedback. No tester names, ratings, quotes, or observations have been invented. Complete DOCUMENTATION/USABILITY_TESTING.md with at least three actual testers before submission, and attach consented photos/screenshots or dated completed feedback records.

Each tester should sign in with a member fixture, locate an available plot, submit a valid request, find request history and an announcement, open settings, trigger an error, and repeat navigation on a mobile device. Record task success, time or difficulty, navigation, readability, interface design, button/link placement, clarity of errors, mobile use, and overall ease of use. Use 1=very difficult/poor through 5=very easy/excellent.

Tester	Device / date	Tasks and ratings	Comments / improvements	Status
Tester 1 - enter actual name/initials	To be recorded	To be recorded	To be recorded	NOT RUN
Tester 2 - enter actual name/initials	To be recorded	To be recorded	To be recorded	NOT RUN
Tester 3 - enter actual name/initials	To be recorded	To be recorded	To be recorded	NOT RUN

Bug / Issue Log

ID / issue	Description / severity	Action taken	Evidence	Status
BUG-01 - registration name validation	Low: browser required 2 characters, but server accepted a single-character name when constraints were bypassed.	Added min:2 to RegisterRequest name rule; added VAL03 regression test.	security-before.xml: VAL03 failed (302 vs expected 422). Final JUnit: VAL03 passed. Screenshot 17 shows server error.	RESOLVED
DOC-01 - human usability evidence	Submission gap: three actual tester sessions not yet provided. No application defect is established.	Provided a structured tester form and procedure; awaiting real responses.	DOCUMENTATION/USABILITY_TESTING.md	PENDING
DOC-02 - member ratings / contributions	Submission gap: leader-approved member details and ratings not provided.	Provided leader/assistant leader form and rating rubric.	DOCUMENTATION/MEMBER_CONTRIBUTIONS.md	PENDING

No critical application defect was identified in this test scope. This statement is limited to the executed checks; deployment and other untested areas are not certified. The initial regression run had 28 passes and 1 failure; after the fix, the final security cases all passed.

Browser Evidence Index

ID / category	Input / procedure	Expected result	Actual result / evidence	Status
B01 Validation	Blank email and password	Required-field errors	Both required-field errors displayed 01-empty-login.png	PASS
B02 Validation	abc	Invalid-email error	Invalid-email message displayed 02-invalid-email.png	PASS
B03 Authentication	Member email with incorrect password	Login denied	Credential error; remains on login page 03-invalid-credentials.png	PASS
B04 SQL injection	Password: ' OR 1=1 --	No login bypass	Credential error and unauthenticated login page 04-sql-login-denied.png	PASS
B05 Authentication	Valid development member credentials	Member dashboard	Member dashboard loaded 05-member-login-success.png	PASS
B06 Authorization	Member requests /members directly	HTTP 403	HTTP 403 access restriction 06-member-access-denied.png	PASS
B07 Interface	Member dashboard at 390 x 844	Fits viewport with mobile navigation	No horizontal overflow 07-mobile-dashboard.png	PASS
B08 Authentication	Logout then GET /member/dashboard	Redirect to login	Final URL /login; login form displayed 08-logout-protected-page.png	PASS
B09 XSS	<script>window.__phase4Xss=1</script> <svg onload="window.__phase4Xss=3"></svg>	Persisted text; no executable DOM or script execution	All three payloads display as literal text to a different user; sentinel remains 0 09-stored-xss-as-text.png	PASS
B10 XSS	<svg onload="window.__phase4Xss=4">	Search field treats payload as text	Literal field value; no SVG handler; sentinel 0 10-reflected-xss-as-text.png	PASS
B11 Functional	Staff creates P4-EVIDENCE, 12.5 square meters, then searches code	Record persists; exactly one matching result	New record visible after full reload and filtered search 11-add-plot-and-search.png	PASS
B12 SQL injection	' OR 1=1 --	Literal search; no extra rows or SQL error	Empty result with normal HTTP 200 page 12-sql-search-empty.png	PASS
B13 Authorization	Admin opens /members	Admin-only roster accessible	Member administration page displayed 13-admin-members-allowed.png	PASS

ID / category	Input / procedure	Expected result	Actual result / evidence	Status
B14 Functional	Admin views reports and requests September CSV export	Report displayed and valid CSV returned	Report visible; HTTP 200 text/csv with expected header 14-report-and-export.png	PASS
B15 Authentication	Authenticated PUT /settings/profile without CSRF token	HTTP 419; no profile change	HTTP 419 request rejected browser-features.txt	PASS
B16 Authentication	Inspect test session cookie attributes	HttpOnly and SameSite=Lax	Both flags present; cookie values omitted from evidence browser-features.txt	PASS
B17 Validation	Registration name A; valid remaining fields; native constraints bypassed by harness	Server rejects name shorter than 2 characters	Server name-length error displayed 17-name-validation-fixed.png	PASS
B18 Interface	Open member navigation at 390 x 844	Visible role-appropriate mobile menu	Member links visible; no horizontal overflow 18-mobile-navigation.png	PASS

SCREENSHOTS/Test_Evidence.pdf contains 16 captioned screenshots. B15 and B16 have structured result evidence in browser-features.txt and browser-results.json. The browser console HTTP 403 corresponds to the deliberate restricted-page test; it is expected.

Complete Backend Test Inventory

Each row is one final executed PHPUnit method. See PROJECT/tests/Feature for its exact fixture inputs, HTTP request sequence and assertions, and EVIDENCE/phpunit-results.xml for its line number and recorded outcome. This inventory counts each method once.

AuthenticationTest

Exact test method	Actual result	Status
test_guests_can_view_authentication_pages	Assertions passed: 18	PASS
test_a_user_can_register_as_a_member	Assertions passed: 7	PASS
test_users_are_redirected_to_their_role_dashboard_after_login	Assertions passed: 15	PASS
test_invalid_credentials_are_rejected	Assertions passed: 3	PASS

CommunityUpdatesTest

Exact test method	Actual result	Status
test_members_receive_only_published_updates_with_the_full_content	Assertions passed: 17	PASS
test_members_can_search_update_titles_and_content	Assertions passed: 22	PASS
test_date_sorting_is_stable_and_pagination_preserves_search_and_sort	Assertions passed: 38	PASS
test_staff_and_admin_share_the_update_management_workflow_and_filters	Assertions passed: 126	PASS
test_members_cannot_use_update_management_actions	Assertions passed: 6	PASS

CropPlantingTest

Exact test method	Actual result	Status
test_staff_can_add_and_edit_crops	Assertions passed: 13	PASS
test_only_staff_can_manage_crops	Assertions passed: 4	PASS
test_grain_is_not_an_available_crop_type	Assertions passed: 3	PASS

Exact test method	Actual result	Status
test_member_can_plant_on_their_active_assignment_and_view_it	Assertions passed: 15	PASS
test_member_cannot_plant_on_someone_elses_or_ended_assignment	Assertions passed: 3	PASS
test_filtered_assignment_history_keeps_the_members_current_plot_visible	Assertions passed: 31	PASS
test_member_without_an_active_plot_does_not_receive_another_members_assignment	Assertions passed: 10	PASS
test_planting_dates_must_be_within_the_assignment_start_and_today	Assertions passed: 8	PASS

DatabaseFoundationTest

Exact test method	Actual result	Status
test_foundational_tables_and_relationships_are_available	Assertions passed: 11	PASS
test_development_seeder_is_repeatable	Assertions passed: 13	PASS
test_demo_data_populates_current_calendar_and_member_history	Assertions passed: 34	PASS

GardenPlotApiTest

Exact test method	Actual result	Status
test_authenticated_users_can_fetch_garden_plots_as_json	Assertions passed: 5	PASS
test_a_member_can_submit_a_valid_plot_request	Assertions passed: 4	PASS
test_plot_request_validation_rejects_unavailable_and_duplicate_requests	Assertions passed: 6	PASS
test_only_members_can_submit_plot_requests	Assertions passed: 1	PASS

MemberBackendTest

Exact test method	Actual result	Status
test_dashboard_shows_only_the_members_latest_activity_and_published_content	Assertions passed: 27	PASS

Exact test method	Actual result	Status
test_new_members_receive_an_empty_dashboard_and_no_member_roster	Assertions passed: 28	PASS
test_web_and_json_submissions_share_validation_and_do_not_create_duplicates	Assertions passed: 20	PASS
test_a_member_can_cancel_and_resubmit_their_pending_request	Assertions passed: 6	PASS
test_cancellation_cannot_change_other_members_or_reviewed_requests	Assertions passed: 11	PASS
test_approval_notifies_all_members_affected_and_cannot_be_replayed	Assertions passed: 11	PASS
test_requests_cannot_be_approved_for_archived_plots_or_ineligible_members	Assertions passed: 6	PASS
test_one_active_assignment_is_enforced_for_requests_and_direct_assignments	Assertions passed: 4	PASS
test_closing_an_assignment_releases_the_plot_without_affecting_its_next_assignment	Assertions passed: 9	PASS
test_planting_dates_respect_the_assignment_end_date	Assertions passed: 6	PASS
test_members_can_only_read_their_own_notifications	Assertions passed: 7	PASS
test_suspended_members_cannot_read_or_write_member_data	Assertions passed: 6	PASS

OperationalWorkflowTest

Exact test method	Actual result	Status
test_member_request_can_be_approved_into_an_assignment	Assertions passed: 6	PASS
test_members_cannot_manage_operational_records	Assertions passed: 3	PASS
test_admin_can_suspend_a_member_and_the_member_cannot_sign_in	Assertions passed: 4	PASS
test_staff_can_publish_an_event_and_notify_active_users	Assertions passed: 3	PASS
test_users_can_update_their_profile_and_password	Assertions passed: 3	PASS
test_staff_can_archive_an_unused_plot_without_losing_history	Assertions passed: 3	PASS
test_operational_reports_can_be_exported_as_csv	Assertions passed: 3	PASS

Exact test method	Actual result	Status
test_admin_cannot_manage_staff_pages	Assertions passed: 6	PASS
test_staff_cannot_open_admin_pages	Assertions passed: 3	PASS

Phase4SecurityTest

Exact test method	Actual result	Status
test_val01_empty_login_fields_are_rejected	Assertions passed: 5	PASS
test_val02_invalid_email_is_rejected	Assertions passed: 4	PASS
test_val03_single_character_registration_name_is_rejected	Assertions passed: 4	PASS
test_val04_duplicate_email_is_rejected	Assertions passed: 4	PASS
test_val05_short_password_is_rejected	Assertions passed: 4	PASS
test_val06_password_confirmation_must_match	Assertions passed: 4	PASS
test_val07_plot_size_must_be_positive_and_status_must_be_valid	Assertions passed: 5	PASS
test_val08_request_notes_enforce_both_length_limits	Assertions passed: 10	PASS
test_val09_event_end_must_be_after_start	Assertions passed: 4	PASS
test_sql01_injection_in_login_email_is_rejected	Assertions passed: 5	PASS
test_sql02_tautology_in_password_cannot_bypass_login	Assertions passed: 4	PASS
test_sql03_union_payload_cannot_bypass_login	Assertions passed: 4	PASS
test_sql04_search_payload_is_bound_as_data_and_returns_no_extra_rows	Assertions passed: 15	PASS
test_sql05_stacked_statement_in_plot_code_is_saved_as_literal_text	Assertions passed: 8	PASS
test_sql06_injection_in_numeric_plot_id_is_rejected	Assertions passed: 4	PASS
test_sql07_legitimate_apostrophes_are_preserved	Assertions passed: 4	PASS

Exact test method	Actual result	Status
test_auth01_login_rotates_session_and_logout_clears_access	Assertions passed: 13	PASS
test_auth02_login_is_throttled_after_five_failed_attempts	Assertions passed: 13	PASS
test_auth03_suspended_account_cannot_login	Assertions passed: 4	PASS
test_auth04_suspension_invalidates_existing_session	Assertions passed: 7	PASS
test_auth05_password_change_requires_current_password	Assertions passed: 4	PASS
test_auth06_anonymous_json_access_requires_authentication	Assertions passed: 2	PASS
test_role01_registration_cannot_assign_admin_or_staff	Assertions passed: 4	PASS
test_role02_member_cannot_promote_themselves	Assertions passed: 2	PASS
test_role03_staff_cannot_modify_member_access	Assertions passed: 3	PASS
test_role04_member_cannot_approve_their_own_request	Assertions passed: 3	PASS
test_xss01_profile_script_is_preserved_as_data_and_escaped_in_html	Assertions passed: 13	PASS
test_xss02_announcement_event_handler_is_transported_as_data	Assertions passed: 13	PASS
test_xss03_reflected_search_is_escaped_in_initial_html	Assertions passed: 12	PASS

RoleAuthorizationTest

Exact test method	Actual result	Status
test_shared_dashboard_redirects_to_the_users_role_dashboard	Assertions passed: 6	PASS
test_role_dashboards_require_the_matching_role	Assertions passed: 30	PASS

WorkspaceNavigationTest

Exact test method	Actual result	Status
test_workspace_pages_are_limited_by_role	Assertions passed: 160	PASS

Exact test method	Actual result	Status
test_calendar_workspace_receives_the_complete_published_schedule_for_both_roles	Assertions passed: 50	PASS
test_staff_plot_management_remains_available_alongside_the_original_gallery	Assertions passed: 26	PASS
test_members_keep_the_original_workspaces_when_a_management_view_is_requested	Assertions passed: 22	PASS
test_member_pages_use_personal_labels	Assertions passed: 16	PASS
test_member_plot_requests_page_receives_only_their_request_details	Assertions passed: 18	PASS
test_member_can_read_the_staff_decision_for_their_request	Assertions passed: 15	PASS
test_member_can_cancel_their_pending_request_and_see_the_updated_history	Assertions passed: 18	PASS
test_member_cannot_cancel_another_members_request	Assertions passed: 2	PASS
test_workspace_pages_require_authentication	Assertions passed: 2	PASS

Members Ratings and Contribution

To be completed and approved by the leader or assistant leader. Use DOCUMENTATION/MEMBER_CONTRIBUTIONS.md to enter actual names, specific tasks with evidence, a rating with the stated scale, and the approving leader's name/date. This report does not assign ratings without that approval.

Final Working Project

PROJECT/ is a fresh source snapshot with the validation fix, current frontend source, migrations, tests, dependency lockfiles, environment templates and production assets. It excludes .env, database files, logs, session data, node_modules, vendor, .git, and unrelated HTML reference files. The previous submission package remains separate. Install instructions are in README_PHASE4.md; local SQLite is suitable for the classroom demonstration, while the normal backend can use PostgreSQL.

Phase 4 Submission Checklist

Requirement	Completion
Input validation tested	DONE
SQL injection testing performed	DONE
Authentication and session handling tested	DONE
Authorization and ownership tested	DONE
Basic stored/reflected XSS tested	DONE
Major functional testing completed	DONE
Human usability testing completed	PENDING - at least 3 actual testers
Test cases documented	DONE
Screenshots and machine-readable evidence included	DONE
Bugs/issues documented and validation fix verified	DONE
Updated source project included	DONE
Member ratings/contributions approved by leader	PENDING
Final testing summary included	DONE

Testing Summary

Metric	Recorded result
Total executed test cases	104 (86 backend + 18 browser)
Passed	104
Failed in final run	0
Fixed application bugs	1 (BUG-01; registration name length)
Known unresolved critical bugs in tested scope	0 identified
Remaining submission items	2: actual human usability feedback; leader-approved member ratings
Human usability sessions	0 recorded; at least 3 required; excluded from executed totals

Complete the two pending human-provided records, reflect their results and any resulting fixes in this report, and then submit the full package. Automated checks cannot establish subjective ease of use or certify every possible vulnerability.